

Aula 2

Segurança da Informação

Prof. Patrick Landal Athayde

Visão geral das normas e padronização

Visão geral das normas de padronização

- As normas de segurança da informação podem ser descritas a partir de uma política de segurança, isto é, um conjunto de regras e padrões que tem por finalidade garantir que as informações valiosas para a instituição sejam protegidas de forma adequada, a fim de se respeitar os pilares da segurança da informação

Considerações importantes para o desenvolvimento de políticas e normas de segurança

- Ao se elaborar uma política ou normativa, é importante que os envolvidos nesta tarefa tenham em mente que estes documentos devem ser criados com intuito de prevenir a ocorrência de problemas com a segurança ou, caso ocorram falhas, para evitar reincidências

- Seu escopo deve ser claro, abrangendo quais os responsáveis e serviços atrelados ao documento, sendo possível a elaboração ou sugestão de criação de comitês de segurança
- (Albuquerque; Ribeiro, 2002), porém isso não é o suficiente

- “Não basta criar um novo departamento ou unidade administrativa e chamá-lo de Comitê Corporativo de Segurança da Informação para que tudo aconteça na organização. É preciso ter uma visão clara e abrangente de todas as etapas que compõem o desafio corporativo da segurança da informação bem como formalizar os processos que darão vida e dinamismo à gestão” (Lyra, 2017, p. 22)

Modelos de especificação da segurança da informação

Modelos de especificação da segurança da informação

- Apesar de seu avanço contínuo, a segurança da informação ainda é considerada uma área relativamente recente no campo das ciências aplicadas, o que resulta em múltiplas interpretações para conceitos fundamentais como ameaça, ativo, vulnerabilidade e ataque. Esses termos são frequentemente empregados com variações conceituais na literatura especializada

Termo	ISO/IEC 15408 (Common Criteria)	ISO/IEC 27000:2018	NIST SP 800-30 Rev.1
Ativo	Entidade associada ao sistema de tecnologia da informação (TI), que requer proteção	Algo que tem valor para a organização	Algo de valor para a organização, podendo incluir pessoas, sistemas, dados, hardware, etc.
Ameaça	Causa potencial de um incidente indesejado, que pode resultar em dano a um ativo	Causa potencial de um incidente indesejado, que pode resultar em dano a um sistema ou organização	Qualquer circunstância ou evento com o potencial de explorar vulnerabilidades e causar danos
Vulnerabilidade	Falha ou fraqueza em um ativo ou grupo de ativos que pode ser explorada por uma ameaça	Fragilidade de um ativo ou controle que pode ser explorada por uma ou mais ameaças	Fraqueza que pode ser explorada por uma ameaça para obter acesso não autorizado ou causar danos
Ataque	Ação de um agente de ameaça que tenta explorar uma vulnerabilidade para comprometer um ativo	Evento ou ação realizada por uma ameaça com o objetivo de comprometer a segurança da informação.	Qualquer tentativa deliberada de explorar uma vulnerabilidade com o propósito de causar danos

- No que se refere à segurança da informação, é muito complexo prevenir e prever todas as possibilidades de ataques, pois a gama de eventos é diversa, inclusive, alguns meios de ataque são impossíveis de prever neste momento

- Logo, podemos dizer que um sistema estará seguro quanto mais defesas possuir contra os ataques mais previsíveis e com a maior perda esperada. A imagem a seguir ilustra como se dá a interpretação de ataques sobre um sistema

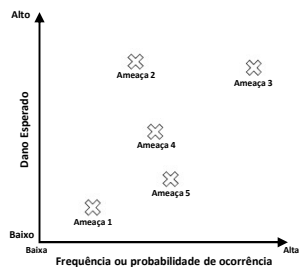
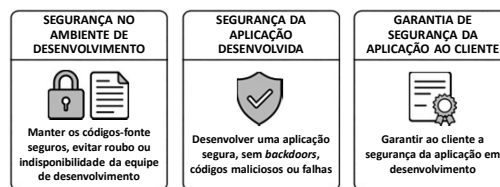


Figura 1: Priorização de ameaças. Fonte: Albuquerque e Ribeiro (2002)

Segurança em desenvolvimento de *software*

- O desenvolvimento seguro de *software* exige atenção coordenada a três dimensões interdependentes: a segurança do ambiente de desenvolvimento, da aplicação e da percepção de segurança pelo cliente

PREOCUPAÇÕES EM DESENVOLVIMENTO SEGURO DE SOFTWARE



Essas preocupações são complementares e indissociáveis

Figura 2: Preocupações em desenvolvimento de software

Segurança do ambiente de desenvolvimento

- Um ambiente seguro para o trabalho é uma preocupação constante das diversas organizações, principalmente entre aquelas que trabalham com objetos de valor, logo, o ambiente de trabalho deve fornecer condições favoráveis para o desenvolvimento de um sistema seguro
- A segurança do ambiente de desenvolvimento de *software* requer práticas estruturadas que garantam controle de acesso, integridade dos artefatos e confidencialidade das informações

Segurança da aplicação desenvolvida

- Durante o desenvolvimento de uma aplicação ou solução, algumas questões devem ser levantadas quanto à satisfação e segurança do cliente
 - Compreender sua necessidade de segurança,
 - Transformar este anseio em especificação do projeto,
 - Implementar esse sistema de forma segura
 - Realizar a validação do sistema, para verificar se a solução atende aos requisitos propostos e às necessidades de segurança do cliente

- Algumas boas práticas de segurança para melhorar o sistema
 - Tratar todas as variáveis de entrada como não confiáveis: cada função deve validar se os valores recebidos estão dentro dos parâmetros aceitáveis e livres de caracteres inválidos ou configurações inadequadas antes de qualquer processamento

- Checar códigos de erro retornados por funções: é fundamental realizar essa verificação, especialmente em chamadas à API do sistema operacional, para prevenir comportamentos inesperados

- Verificar o tamanho de *buffers* e *arrays*: atenção especial deve ser dada ao uso de funções de biblioteca, uma vez que a falta de validação pode provocar estouro de *buffer*
- Garantir comunicação eficiente entre os envolvidos no projeto: a documentação do código é essencial para evitar falhas no desenvolvimento, promovendo alinhamento e clareza entre os membros da equipe

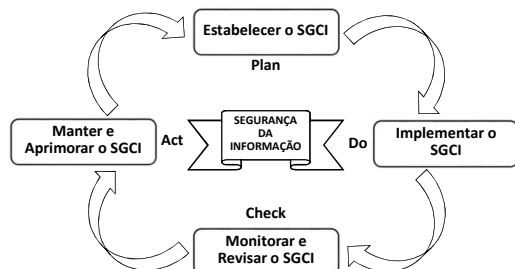
Garantia de segurança

- A garantia de segurança em sistemas vai além do desenvolvimento seguro: envolve oferecer mecanismos que permitam ao cliente confiar na proteção do sistema entregue. Para isso, é recomendável possibilitar a validação da segurança por parte do cliente, seja por meio da verificação dos testes realizados, seja pela realização de testes independentes

Sistema de Gestão em Segurança da Informação (SGSI)

- O SGSI, ou *Information Security Management System (ISMS)*, corresponde ao conjunto de ações, políticas, procedimentos e modelos destinados à mitigação de riscos associados à segurança da informação

- A construção do SGSI costuma seguir o ciclo PDCA (*plan-do-check-act*), metodologia reconhecida por sua eficácia na resolução de problemas e promoção da melhoria contínua em diversos contextos organizacionais, desde a gestão de projetos até a governança corporativa
- O ciclo PDCA apresenta como principal vantagem sua flexibilidade metodológica, sendo aplicável a diferentes setores e portes organizacionais, o que o torna uma ferramenta transversal (Paladini, 2012)



Common Criteria for Technology Security Evaluation (ISO/IEC 15408)

Common Criteria for Technology Security Evaluation (ISO/IEC 15408)

- A norma ISO/IEC 15408, conhecida como **Common Criteria (CC)**, estabelece um referencial técnico para especificar e avaliar requisitos de segurança em produtos e sistemas de TI (ISO/IEC, 2009)
- Seu objetivo é padronizar a definição de atributos de segurança através do **Security Target (ST)**, um documento que detalha os objetivos e mecanismos de proteção de uma solução específica

- Para medir a confiança na segurança, o CC utiliza sete Níveis de Garantia de Avaliação (**Evaluation Assurance Levels – EALs**), que representam um rigor metodológico crescente

Nível EAL	Descrição	Objetivo Principal	Aplicação Comum
EAL1	Funcionalmente testado	Confirmação de que as funções de segurança estão presentes e foram testadas.	Aplicação rápida e econômica de produtos genéricos.
EAL2	Testado estruturalmente	Requer uma análise da arquitetura do produto e testes independentes.	Produto de uso geral com necessidades moderadas.
EAL3	Testado metodicamente e verificado	Exige revisão de desenvolvimento de testes formais e controle de configuração	Aplicações corporativas que exigem maior confiança
EAL4	Projetado, testado e revisado metodicamente	Oferece uma análise mais detalhada, testes independentes e análise de vulnerabilidades.	Produtos comerciais de missão crítica.
EAL5	Projetado semiestruturalmente e testado	Exige documentação mais completa, testes mais rigorosos e medidas para proteger o projeto.	Ambientes sensíveis e sistemas militares.
EAL6	Projetado estruturalmente para alta segurança	Avaliação profunda, análise completa de segurança e mitigação de ataques sofisticados.	Sistemas financeiros ou militares altamente críticos.
EAL7	Projetado formalmente e testado	Nível máximo: exige especificação formal, desenvolvimento controlado, testes formais e validação exaustiva.	Infraestruturas críticas com altíssimo risco.

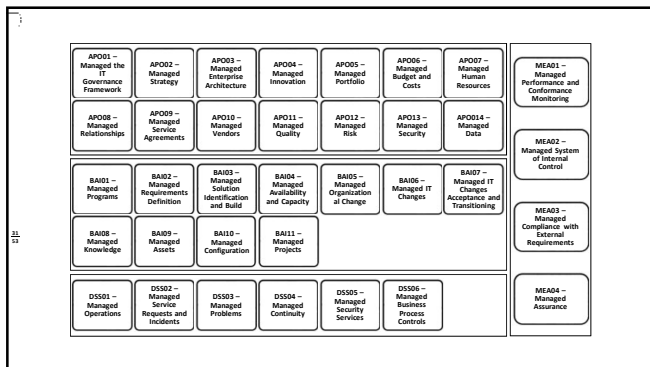
Control Objectives for Information and Related Technologies (CobiT)

Control Objectives for Information and Related Technologies (CobiT)

- O CobiT é um **framework** desenvolvido pela ISACA que fornece princípios e práticas para alinhar a TI aos objetivos de negócio, garantindo controle e conformidade
- É considerado uma das melhores práticas mundiais para controles de TI, especialmente no setor financeiro

Divisão da estrutura

- O CobiT é organizado em quatro domínios principais
 - Alinhar, planejar e organizar (*align, plan, organize – APO*)
 - Construir, adquirir e implementar (*build, acquire, implement – BAI*)
 - Entrega, serviço e suporte (*delivery, service, support – DSS*)
 - Monitoramento, avaliação e análise (*monitor, evaluate, assess – MEA*)



APO

- O domínio APO, segundo o *framework* CobIT, constitui um pilar estratégico da gestão de TI, promovendo sua integração com os objetivos organizacionais** (Isaca, 2019)

APO

- Sua eficácia está vinculada à capacidade de responder a questionamentos críticos, tais como**
 - Alinhamento estratégico: como a TI suporta diretamente as metas de negócio?**

APO

- Otimização de recursos: de que forma os investimentos em TI maximizam retorno e eficiência?**
- Governança integrada: quais mecanismos asseguram a coerência entre decisões tecnológicas e operacionais?**

BAI

- O domínio BAI, conforme definido pelo *framework* CobIT, concentra-se na criação, aquisição e implementação de soluções tecnológicas alinhadas às demandas organizacionais** (Isaca, 2019)
- Sua principal função é garantir que os projetos de TI sejam entregues com qualidade, dentro do prazo estabelecido e em conformidade com os requisitos definidos, assegurando ainda o controle adequado em todo o ciclo de vida**

BAI

- Este domínio abrange processos essenciais como**
 - Gestão de projetos e mudanças**
 - Administração de ativos e configurações**
 - Definição e validação de requisitos**
 - Transição de serviços para produção**

BAI

- Questões centrais que orientam este domínio
 - As soluções atendem aos requisitos funcionais e estratégicos do negócio?
 - Os projetos seguem metodologias formais para mitigar riscos e desvios?
 - Os processos de alteração são controlados e preservam a continuidade dos serviços?
 - A implantação ocorre de forma estruturada e segura?

DSS

- O domínio DSS foca na entrega eficaz dos serviços de TI, suporte ao usuário e manutenção da operação contínua e segura dos sistemas
- Visa garantir disponibilidade, confiabilidade e proteção dos serviços, além de assegurar respostas eficientes a incidentes, requisições e problemas operacionais

DSS

- Alguns questionamentos
 - Os serviços de TI são prestados com níveis aceitáveis de qualidade, disponibilidade e segurança?
 - Existe um processo eficiente para tratamento de incidentes e resolução de problemas?

DSS

- As operações de TI são gerenciadas com base em controles e práticas consistentes?
- A organização está preparada para manter a continuidade dos serviços em situações adversas?

MEA

- O domínio MEA trata da avaliação contínua do desempenho, da conformidade e dos controles internos de TI
- Seu objetivo é promover transparência, auditoria e responsabilização, garantindo o alinhamento das ações de TI com políticas, normas e exigências legais

MEA

- Engloba o monitoramento da performance organizacional, a avaliação da eficácia dos controles internos e a verificação da conformidade com requisitos internos e externos

MEA

- Entre as perguntas fundamentais que este domínio procura responder, destacam-se
- Os processos de TI estão sendo monitorados quanto ao desempenho e conformidade?
- Os controles internos são eficazes e devidamente auditados?

MEA

- A organização está em conformidade com os requisitos legais, regulatórios e contratuais?
- Os relatórios de desempenho e riscos de TI são comunicados aos *stakeholders* de forma clara e tempestiva?

Information Technology Infrastructure Library (ITIL)

Information Technology Infrastructure Library (ITIL)

- Um grupo de organizações industriais e governamentais do Reino Unido se organizou no final dos anos 80 para a promoção de um documento norteador para gestão de serviços em TI, o que levou à constituição do ITIL
- Biblioteca para infraestrutura de serviços de TI, inicialmente composto por 60 livros, como um conjunto de práticas em TI

- “Para garantir que permaneçam relevantes e bem-sucedidas, muitas organizações estão se engajando em programas de transformação de grande porte com o objetivo de explorar essas oportunidades. Embora essas transformações sejam frequentemente denominadas ‘digitais’, elas vão além da tecnologia: tratam-se de uma evolução na forma como as organizações operam, permitindo que prosperem diante de mudanças contínuas e significativas” (ITIL, 2019, p. 2)

- A proposta ITIL tem por finalidade propor uma estratégia que possamos aplicar em qualquer tipo de organização, considerando a gestão em serviços de TI como um conjunto de processos fortemente interligados. Os objetivos da gestão em serviços de TI devem levar em conta três pilares: pessoal envolvido, processos e tecnologia

- É importante ressaltar que os processos propostos pela ITIL são aplicados como base de conformidade para as normas BS 15000 (*British Standard for IT Service Management*) e ISO/IEC 20000

Referências

- FERREIRA, F. N. F.; ARAUJO, M. T. Política de segurança da informação: guia prático para elaboração e implementação. Ciência Moderna LTDA, Rio de Janeiro, 2008.
- LYRA, M. R. Segurança e auditoria em sistemas de informação. Rio de Janeiro: Ciência Moderna LTDA, 2017

- NIST. An introduction to information security: NIST Special Publication 800-12 Revision 1. Gaithersburg, MD: National Institute of Standards and Technology, 2017. Disponível em: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>. Acesso em: 06 maio 2025.
- ISO/IEC 27002:2022. Information Security, Cybersecurity and Privacy Protection – Code of Practice for Information Security Controls

- Howard, M., LeBlanc, D. Writing secure code. 2. ed. Microsoft Press, 2003.
- OWASP (2023). Secure Software Development Lifecycle (S-SDLC). 2023. Disponível em: <https://owasp.org/www-project-secure-software-development-life-cycle/>. Acesso em: 06 maio 2025.
- ISO/IEC 15408. Common Criteria for Information Technology Security Evaluation. Disponível em: <https://www.commoncriteriaportal.org>. Acesso em: 06 maio 2025.